

Cybersecurity Basics 1 Project, Rubric 4

Demonstrate Legal and Ethical Compliance

Include a section that explains legal and ethical compliance in your incident response plan. Identify at least two relevant laws or regulations, discuss at least one ethical consideration, and explain how your plan upholds these legal requirements and ethical principles.

Legal and Ethical Compliance in Incident Response

1. Relevant Laws & Regulations

- **General Data Protection Regulation (GDPR - Article 33):** Requires organizations to report personal data breaches to the relevant supervisory authority within 72 hours of becoming aware of the incident, unless the breach is unlikely to result in a risk to individuals' rights and freedoms.
- **Health Insurance Portability and Accountability Act (HIPAA Breach Notification Rule):** Mandates that covered entities notify affected individuals, the U.S. Department of Health & Human Services (HHS), and in some cases the media, following a breach of Unsecured Protected Health Information (PHI) without unreasonable delay and no later than 60 calendar days after discovery.

2. Ethical Consideration

- **Transparency vs. Premature Disclosure:** Balancing the ethical duty to inform affected users promptly about potential risk to their privacy against the risk of disclosing unverified information that could cause unnecessary panic or expose ongoing security vulnerabilities before containment is fully achieved.

3. Alignment with Legal and Ethical Principles

Principle	Plan Enforcement	Impact
GDPR & HIPAA Compliance	• Escalation paths integrated into Phase 2 (Identification).	Ensures reporting thresholds (72 hours for GDPR, up to 60 days for HIPAA) are strictly met to avoid regulatory penalties and fulfill user notification obligations.
	• Automated timestamping and legal team notifications during triage.	

**Ethical
Transparency**

- Controlled communication protocols in Phase 3 (Containment) and Phase 5 (Recovery).

Prevents spreading misinformation while providing impacted users timely, accurate details to protect themselves (e.g., changing passwords, monitoring credit).

- Public advisories are clear, actionable, and verified by forensics.

**Duty of Care &
Confidentiality**

- Secure forensics logging and encrypted evidence storage during investigation.

Upholds user trust and ethical privacy standards by ensuring evidence collected during a breach does not expose additional sensitive user data.

- Minimal necessary exposure of evidence to non-essential staff.